

Academic Year 2025 – 2026

Disclaimer

The work presented in this report was carried out as part of an academic internship. All technical choices, deployments, and simulations were performed within a controlled, self-contained virtual environment. The descriptions of infrastructure limitations or environmental constraints refer exclusively to the internship context and do not constitute a reflection of the actual operational capabilities of any institution mentioned herein.

Acknowledgements

I would like to express my sincere gratitude to all those who supported this project.

First and foremost, I thank my academic supervisor, Pr. Tarek Ait Baha, for his consistent guidance, constructive feedback, and availability throughout the project.

I am equally grateful to my professional supervisors, Ms. Soukaina Boukha (HR Manager) and Mr. Abdellatif Oubousseksou (IT Manager), for sharing their business requirements and for validating the prototype against real operational expectations.

I also thank the entire CRI Guelmim team for their warm welcome and their readiness to explain the day-to-day realities of HR management in a public institution.

Finally, I thank my family and friends for their encouragement throughout this internship period.

Abstract

Title: Secure Design and Deployment of an HR Module Integrated into an ERP System — The Case of CRI Guelmim.

This project addresses the absence of a digital HR solution at the Regional Investment Centre (CRI) of Guelmim-Oued Noun. Within the constraints of the internship context (no production server access), an autonomous prototype was designed and deployed on a virtual machine simulating an internal network, based on Odoo 17 containerised with Docker and exposed via an Nginx reverse proxy over HTTPS.

The prototype delivers core HR functions — employee management, leave requests, and role-based approval workflows — enforced by a three-tier authorisation model (RBAC). A layered security architecture was built on top of the application, combining transport-layer encryption, IP access traceability, SQL-injection auditing (SQLmap), automated brute-force mitigation (Fail2Ban), configuration integrity monitoring (Auditd), and real-time infrastructure observability (Netdata).

The report documents the full engineering process: requirements analysis, technical choices, implementation, security validation, and professional assessment. Results confirm that all functional and security objectives were met within the six-week internship constraint.

Keywords: ERP, Odoo 17, HR module, HTTPS, RBAC, Docker, Nginx, Fail2Ban, Auditd, Netdata, penetration testing, virtual machine, RIS, security hardening.

Contents

Disclaimer	i
Acknowledgements	ii
Abstract	iii
List of Abbreviations	viii
1 Introduction	1
2 Organisational Context and Project Framing	2
2.1 Presentation of CRI Guelmim	2
2.1.1 Definition and Missions	2
2.1.2 Organisational Chart	2
2.2 HR Service: Current Workflow and Identified Gaps	3
2.3 Project Scope and Constraints	3
2.4 Alignment with the RIS Programme	4
3 Theoretical Background and State of the Art	5
3.1 ERP Systems: Principles and Benefits	5
3.2 Odoo: An Open-Source ERP Platform	5
3.3 Security Challenges in ERP Deployments	5
3.4 Defence-in-Depth Architecture	6
4 Methodology and Tools	7
4.1 Agile Approach (Scrum)	7
4.2 Technical Environment	7
4.3 Sprint Planning	8
5 Implementation of the Secure HR Prototype	9
5.1 Technical Architecture	9
5.2 Environment Setup	10
5.2.1 Docker Compose	10
5.2.2 Custom Docker Image	11
5.3 HR Module Configuration	11
5.4 Virtual Machine Network Configuration	12
5.5 Security Hardening	13
5.5.1 HTTPS with Nginx	13

5.5.2	IP Access Logging	14
5.5.3	Role-Based Access Control	14
5.5.4	SQL-Injection Audit (SQLmap)	14
5.5.5	Brute-Force Mitigation with Fail2Ban	15
5.5.6	File Integrity Monitoring with Auditd	16
5.5.7	Real-Time Infrastructure Monitoring with Netdata	17
5.5.8	Attack Simulation and Incident Response Validation	17
6	Results and Analysis	20
6.1	Functional Results	20
6.2	Performance Metrics	20
6.3	Security Validation Results	20
6.4	Comparison with Initial Objectives	21
7	Discussion and Professional Interpretation	22
7.1	Achievement vs. Requirements	22
7.2	Identified Limitations and Engineering Trade-offs	22
7.3	Contributions	22
7.4	The Role of AI in Modern Cybersecurity	23
7.5	Future Work	23
8	Conclusion	25
	Bibliography	25
A	Configuration Files	27
B	SQLmap Execution Log (Extract)	29

List of Figures

2.1	Organisational chart of CRI Guelmim-Oued Noun	2
5.1	Logical architecture — 3-tier, Docker, VirtualBox Host-Only network . . .	10
5.2	Odoo login page — HTTPS connection confirmed	12
5.3	HR module — employees list with RBAC-controlled columns	12
5.4	VirtualBox — Host-Only adapter configuration (static IP 192.168.56.101) .	13
5.5	Nginx access log — client IP recorded per authenticated request	14
5.6	SQLmap execution — 432 tests, 0 injectable parameters detected	15
5.7	Fail2Ban — service active (running), odoo-https jail enabled .	16
5.8	Auditd — watch rules applied, service active (running)	16
5.9	Netdata dashboard — live CPU, RAM, and network metrics	17
5.10	Attack flow: brute-force detection and automatic mitigation by Fail2Ban, with parallel monitoring by Netdata and Auditd.	18

List of Tables

2.1	Functional scope of the CRI-HR-Secure prototype	3
4.1	Tools and technologies used	7
4.2	Six-week sprint plan	8
5.1	Security controls — implementation and validation summary	19
6.1	Initial objectives vs. achieved outcomes	21

List of Abbreviations

Acronym	Definition
API	Application Programming Interface
CRI	Centre Régional d'Investissement (Regional Investment Centre)
ERP	Enterprise Resource Planning
HTTPS	HyperText Transfer Protocol Secure
IP	Internet Protocol
LDAP	Lightweight Directory Access Protocol
MFA	Multi-Factor Authentication
Nginx	Engine-X — open-source web server and reverse proxy
Odoo	Open-source ERP platform (formerly OpenERP)
OWASP	Open Web Application Security Project
RBAC	Role-Based Access Control
RIS	Réseaux Informatiques et Sécurité (Computer Networks and Security)
SIEM	Security Information and Event Management
SQL	Structured Query Language
TLS	Transport Layer Security
VM	Virtual Machine

Introduction

Moroccan public institutions are under increasing pressure to modernise their internal processes as part of the national digital transformation strategy. The Regional Investment Centre (CRI) of Guelmim-Oued Noun is no exception: its HR department currently relies on paper-based leave requests, manually maintained Excel files, and a complete absence of digital traceability — a situation that generates processing delays, data inconsistencies, and uncontrolled exposure of sensitive personnel information.

This final-year project, carried out under the RIS programme at the Higher School of Technology of Guelmim (ESTG), proposes a response to this gap: the design and deployment of a secure HR module prototype based on the Odoo ERP platform. Given the typical constraints of an academic internship (no production server access), the scope was adjusted to an autonomous prototype deployed on a virtual machine, with a deliberate emphasis on security engineering rather than functional breadth.

The work covers the complete project lifecycle: requirement capture, architecture design, containerised deployment, security hardening, and systematic validation. The following chapters are organised as follows:

- **Chapter 2** situates the project within the CRI's organisational context and defines the scope and constraints.
- **Chapter 3** provides the theoretical background on ERP systems, open-source HR platforms, and ERP security challenges.
- **Chapter 4** describes the methodology and the technical environment.
- **Chapter 5** details the full implementation of the secure prototype.
- **Chapter 6** presents and analyses the results against the initial objectives.
- **Chapter 7** offers a professional discussion of achievements, limitations, and future directions.

Organisational Context and Project Framing

2.1 Presentation of CRI Guelmim

2.1.1 Definition and Missions

The **Centre Régional d'Investissement (CRI)** of Guelmim-Oued Noun is a Moroccan public institution created in October 2002 to simplify business creation procedures and promote regional economic development. It employs approximately twenty people distributed across administrative, communication, and HR departments.

Its core missions are:

- Serving as a single point of contact for investors in the region.
- Providing a one-stop shop for investment files, from application to permit delivery.
- Advising businesses on land allocation, subsidies, and financing opportunities.
- Ensuring the secretariat of the Regional Unified Investment Commission (CRUI).

2.1.2 Organisational Chart

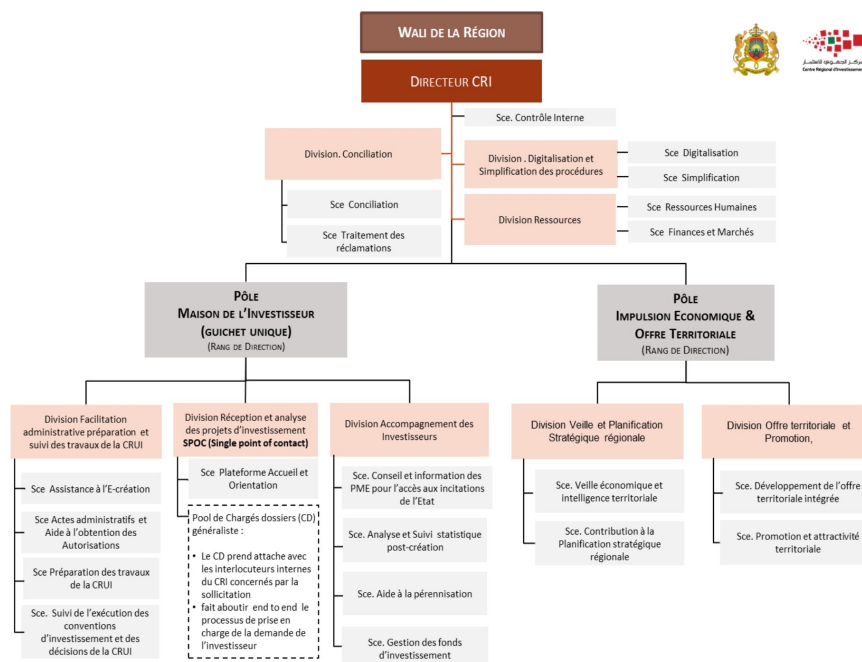


Figure 2.1. Organisational chart of CRI Guelmim-Oued Noun

2.2 HR Service: Current Workflow and Identified Gaps

The HR department currently operates without any digital system. Employee records are stored in paper folders and Excel spreadsheets; leave requests are submitted on printed forms, manually forwarded to the Director for approval, and archived in physical binders. This workflow leads to four concrete operational problems:

1. **Slow processing.** A leave request can take several days to reach approval due to manual routing.
2. **No centralisation.** Employee data is fragmented across multiple files with no single authoritative source.
3. **No traceability.** There is no audit trail for approvals, modifications, or access to personnel files.
4. **Data exposure.** Sensitive HR data (salaries, medical leaves, personal information) is accessible to anyone with physical access to the filing system.

2.3 Project Scope and Constraints

Table 2.1. Functional scope of the CRI-HR-Secure prototype

Feature	Status
Employee CRUD (name, email, position, department, hire date)	Included
Leave request workflow (annual, sick, unpaid)	Included
Leave approval by HR Officer	Included
Authentication and RBAC (Admin, HR Officer, Employee)	Included
Dashboard (employee count, pending requests)	Included
HTTPS via Nginx reverse proxy (self-signed certificate)	Included
IP access logging	Included
SQL-injection penetration test (SQLmap)	Included
Brute-force protection (Fail2Ban)	Included
File integrity monitoring (Auditd)	Included
Real-time system monitoring (Netdata)	Included
Payroll, recruitment, performance reviews	Excluded
Integration with external systems	Excluded
Deployment on a production CRI server	Excluded*

*The internship was conducted in a fully virtualised environment; deployment on a production server was not required.

Key constraints that shaped the technical choices are:

- The work was carried out on a local virtual machine – a standard practice for this type of academic prototype.

- No existing ERP or database to integrate with.
- Available RAM on the development machine: 4.5 GB (influenced tooling choices, notably the decision not to deploy a full SIEM stack).
- Time constraint: six weeks.

2.4 Alignment with the RIS Programme

The RIS specialisation aims to produce engineers capable of designing network infrastructures, securing information systems, and administering Linux servers. This project directly exercises all three competency areas: network isolation via VirtualBox Host-Only; system security through hardening, encryption, and intrusion prevention; and system administration through Docker, Nginx, PostgreSQL, and Ubuntu Server deployment.

Theoretical Background and State of the Art

3.1 ERP Systems: Principles and Benefits

An Enterprise Resource Planning (ERP) system consolidates all operational and management data into a single, integrated database accessible to authorised users across an organisation. Key benefits include reduced data redundancy, improved cross-departmental communication, real-time reporting, and a single authoritative source of record for business decisions.

For a public institution such as the CRI, an ERP-based HR module specifically enables digital leave tracking, centralised employee records, and an auditable approval workflow — directly addressing the four operational gaps identified in Chapter 2.

3.2 Odoo: An Open-Source ERP Platform

Odoo is the leading open-source ERP platform in terms of community adoption and module coverage. Its Community edition is freely available under the LGPL licence, making it a viable option for resource-constrained public institutions. Odoo is built on Python and follows a model-view-controller (MVC) architecture, using PostgreSQL as its persistence layer. The `hr` and `hr_holidays` modules provide the employee management and leave workflow features required for this project.

3.3 Security Challenges in ERP Deployments

ERP systems are high-value targets: they centralise sensitive business data and are typically accessible over a network. The OWASP Top 10 [9] identifies the most critical web application vulnerabilities; several are directly relevant to an Odoo deployment: injection (SQL), broken authentication, and security misconfiguration. A production-grade ERP deployment must address at minimum: strong authentication, role-based authorisation, encrypted communication, audit logging, network isolation, and regular penetration testing.

ERP login interfaces are particularly exposed to **credential stuffing** and **brute-force attacks**, in which automated tools submit large volumes of username/password combinations extracted from public breach databases. A typical Odoo deployment accessible over HTTPS offers no native rate-limiting on the `/web/login` endpoint, making it vulnerable to sustained

automated authentication attempts unless an external mitigation layer is in place. This specific threat directly motivated the deployment of Fail2Ban in this project (Section 5.5.5).

Similarly, any file-based misconfiguration — a modified Nginx reverse-proxy rule or a tampered Docker Compose file — can silently downgrade the security posture without triggering any application-level alert. This threat motivated the deployment of Auditd (Section 5.5.6) as an independent integrity-verification layer operating below the application stack.

3.4 Defence-in-Depth Architecture

Defence-in-depth is the principle of layering independent security controls so that the failure of any single control does not lead to a complete compromise. Applied to this project, it means combining transport encryption (HTTPS), access control (RBAC), intrusion prevention (Fail2Ban), integrity monitoring (Auditd), and observability (Netdata) — each layer addressing a distinct threat vector and compensating for the limitations of the others.

Methodology and Tools

4.1 Agile Approach (Scrum)

Work was organised into six weekly sprints, each with a planning session, daily progress checks, and an end-of-week review. This lightweight Scrum adaptation allowed early delivery of a working prototype (Sprint 2) and iterative security hardening in subsequent sprints, rather than deferring all security work to the final week.

4.2 Technical Environment

Table 4.1. Tools and technologies used

Category	Tool / Version	Role
ERP platform	Odoo 17 Community	HR application layer
Database	PostgreSQL 15	Persistent data store
Containerisation	Docker + Compose	Service isolation and portability
Reverse proxy	Nginx (Alpine)	TLS termination, IP logging
Virtualisation	VirtualBox + Ubuntu 22.04 LTS	Isolated deployment environment
Certificates	OpenSSL 3.x	Self-signed TLS certificate (RSA-4096)
Security testing	SQLmap 1.8	SQL-injection audit
IPS	Fail2Ban 1.x	Automated brute-force mitigation
Audit	Auditd (Linux Audit)	File-integrity and access logging
Monitoring	Netdata	Real-time system observability
Documentation	L ^A T _E X (pdf _l atex)	Report typesetting

4.3 Sprint Planning

Table 4.2. Six-week sprint plan

Sprint	Focus	Deliverable
1	Requirements analysis, VM setup, DB design	Entity-relationship diagram, network diagram
2	Odoo installation, Docker, custom image	Odoo running locally on HTTP
3	HR modules, RBAC configuration	Employee CRUD and leave workflow functional
4	HTTPS, Nginx reverse proxy, IP logging	Encrypted access, access log confirmed
5	Security hardening + penetration tests	Fail2Ban, Auditd, Netdata, SQLmap report
6	Final report, defence preparation	Complete report and presentation slides

Implementation of the Secure HR Prototype

5.1 Technical Architecture

The prototype follows a three-tier architecture deployed entirely within a VirtualBox Host-Only network, isolating it from any external internet access:

- **Client tier:** A Windows workstation accesses the application exclusively via HTTPS over the Host-Only network (192.168.56.0/24).
- **Application tier:** An Ubuntu 22.04 LTS VM (IP 192.168.56.101, 2 vCPU, 2 GB RAM) hosts two Docker containers: an Nginx container (reverse proxy, TLS termination on port 443) and an Odoo 17 container (application server, internal port 8069).
- **Data tier:** A third Docker container running PostgreSQL 15 (internal port 5432, not exposed to the host) stores all application data in a persistent named volume.

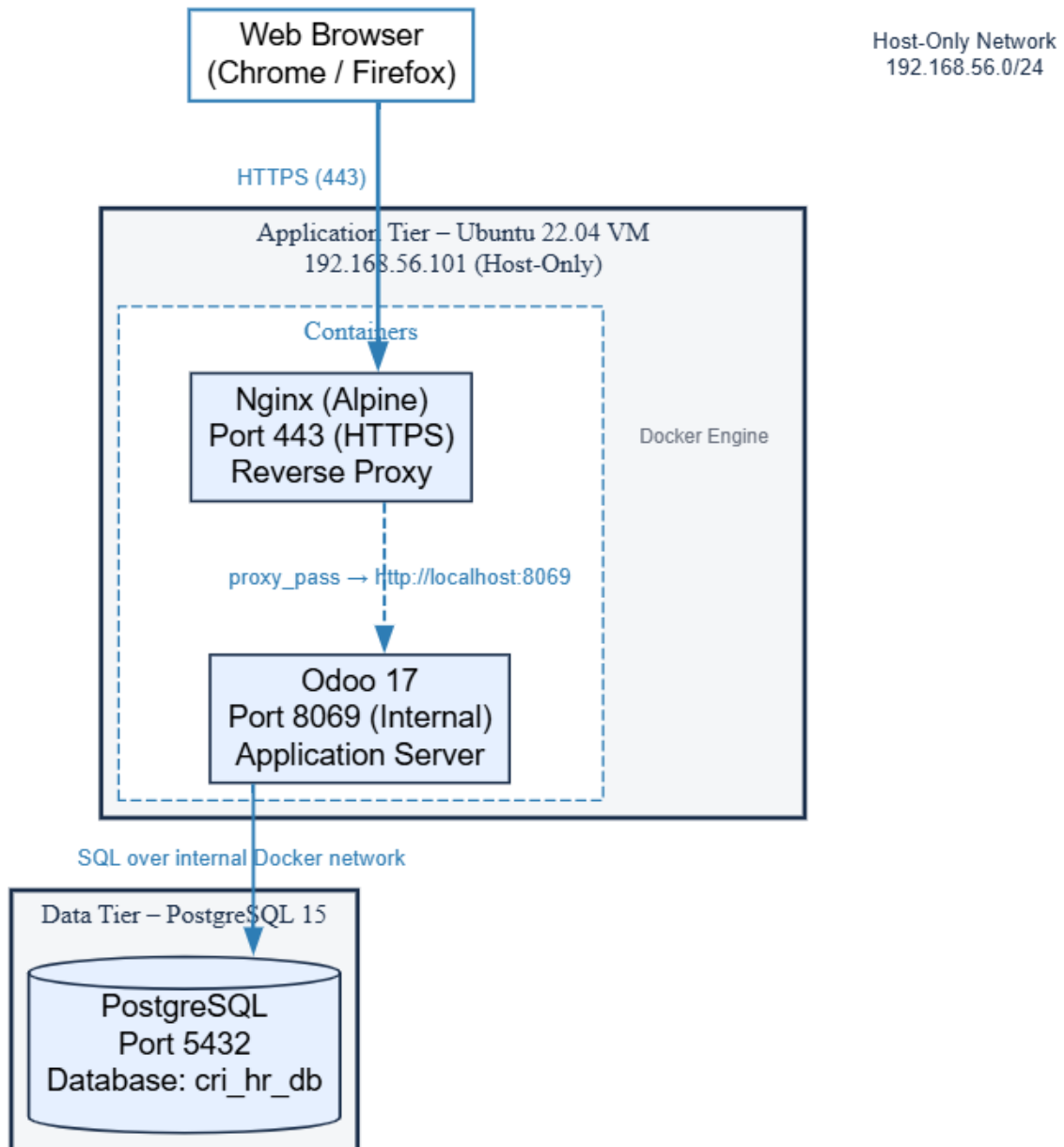


Figure 5.1. Logical architecture — 3-tier, Docker, VirtualBox Host-Only network

5.2 Environment Setup

5.2.1 Docker Compose

All services are defined in a single `docker-compose.yml` file, ensuring reproducible deployment with a single command:

```

1 version: '3.8'
2 services:
3   db:
4     image: postgres:15
5     environment:
6       POSTGRES_USER:      odoo

```

```
7     POSTGRES_PASSWORD: odoo
8     POSTGRES_DB:      postgres
9     volumes:
10      - postgres_data:/var/lib/postgresql/data
11
12     odoo:
13       image: cri-odoo-custom:v1
14       ports:
15        - "8069:8069"
16       depends_on:
17        - db
18       volumes:
19        - odoo_data:/var/lib/odoo
20
21 volumes:
22   postgres_data:
23   odoo_data:
```

Listing 5.1. docker-compose.yml

5.2.2 Custom Docker Image

A minimal Dockerfile extending the official Odoo image was created and tagged as `cri-odoo-custom:v1`. The image was built on the development machine, exported as a compressed archive, and transferred to the Ubuntu VM for offline loading — circumventing the need for internet access on the VM:

```
1 docker build -t cri-odoo-custom:v1 .
2 docker save cri-odoo-custom:v1 | gzip > cri-odoo-custom.tar.gz
3 # On the VM:
4 docker load -i cri-odoo-custom.tar.gz
```

Listing 5.2. Build and transfer the custom image

5.3 HR Module Configuration

After launching the containers, the `crihrdb` database was created through the Odoo web interface and the `Employees` and `Time Off` modules were installed. Three user accounts were created to map the required organisational roles: `admin` (Administrator), `ahmed_elalami` (HR Officer), and `fatima_zahra` (Employee). Access boundaries were verified by attempting restricted operations with each account.

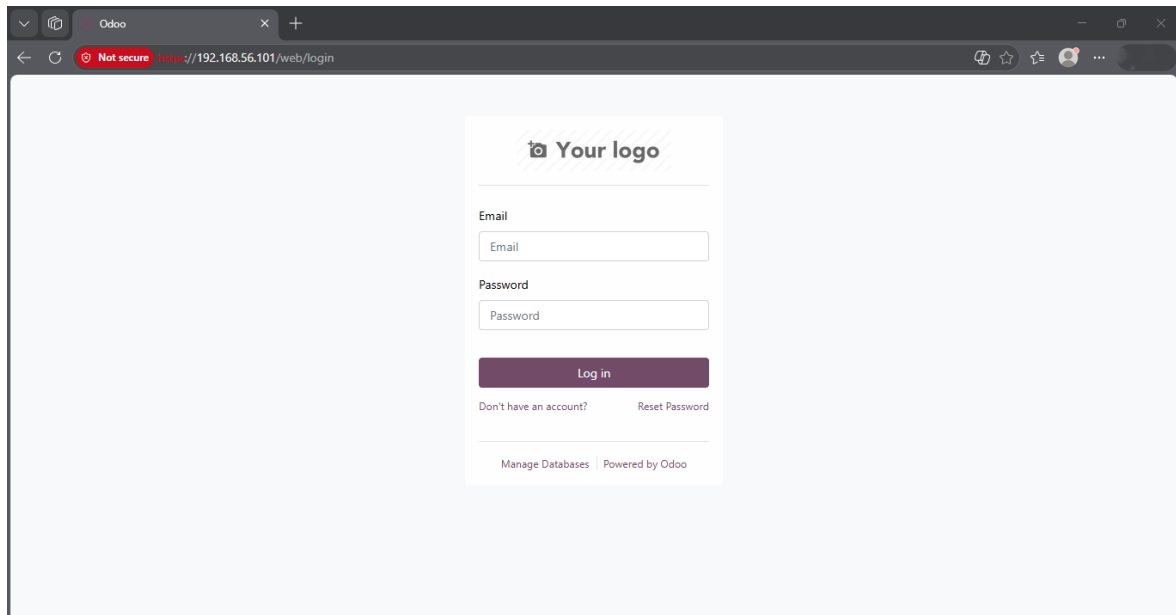


Figure 5.2. Odoo login page — HTTPS connection confirmed

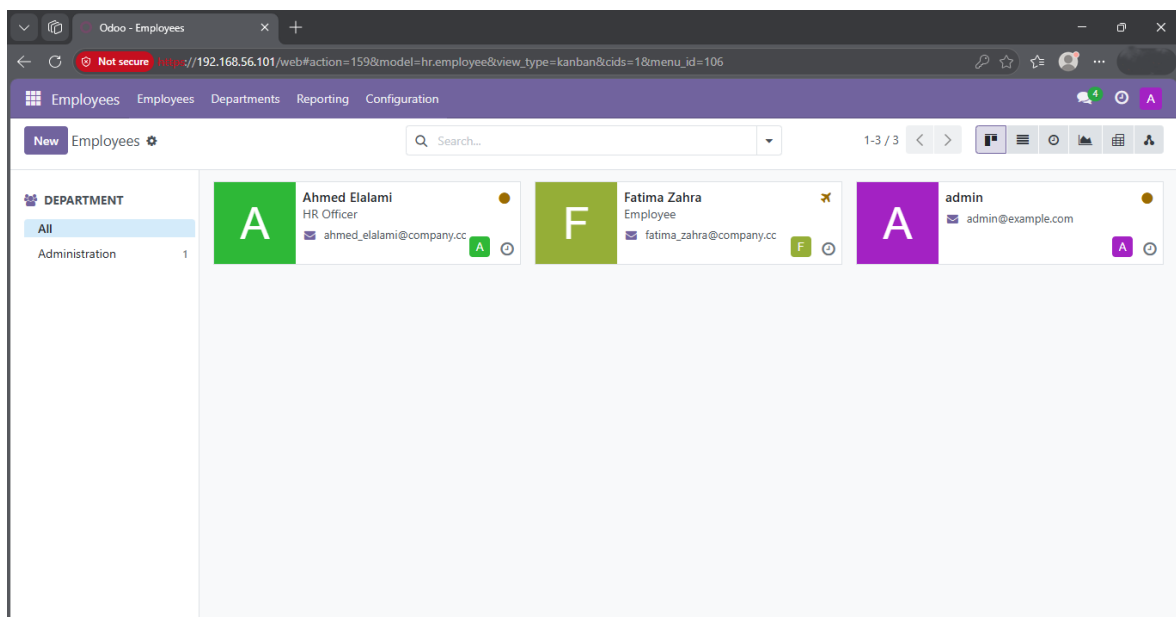


Figure 5.3. HR module — employees list with RBAC-controlled columns

5.4 Virtual Machine Network Configuration

The Ubuntu VM was configured with two network interfaces: a NAT adapter for outbound internet access during the setup phase, and a Host-Only adapter providing the isolated internal network on which Odoo is served. Netplan was used to assign the static IP address 192.168.56.101 to the Host-Only interface, ensuring a predictable and stable endpoint for all client connections.

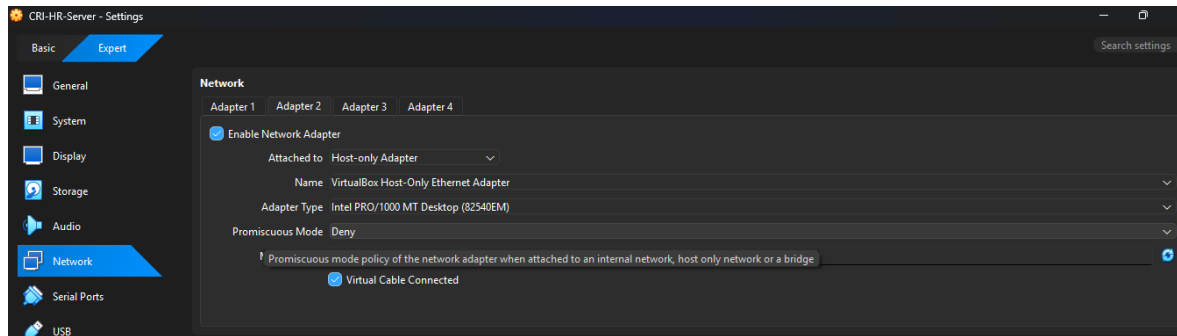


Figure 5.4. VirtualBox — Host-Only adapter configuration (static IP 192.168.56.101)

5.5 Security Hardening

5.5.1 HTTPS with Nginx

Nginx was installed on the Ubuntu VM host (not inside the container) and configured as a TLS-terminating reverse proxy. A 4096-bit RSA self-signed certificate was generated with OpenSSL and bound to the VM's static IP. All inbound connections on port 443 are decrypted by Nginx and forwarded in plain HTTP to the Odoo container on `localhost:8069`, ensuring that credentials and session tokens are never transmitted in clear text across the network.

```

1 sudo openssl req -x509 -newkey rsa:4096 \
2   -keyout /etc/ssl/private/key.pem \
3   -out    /etc/ssl/certs/cert.pem \
4   -days 365 -nodes \
5   -subj "/CN=192.168.56.101"
```

Listing 5.3. RSA-4096 self-signed certificate generation

```

1 server {
2     listen 443 ssl;
3     server_name 192.168.56.101;
4
5     ssl_certificate      /etc/ssl/certs/cert.pem;
6     ssl_certificate_key  /etc/ssl/private/key.pem;
7
8     location / {
9         proxy_pass        http://localhost:8069;
10        proxy_set_header  Host            $host;
11        proxy_set_header  X-Real-IP       $remote_addr;
12        proxy_set_header  X-Forwarded-For $proxy_add_x_forwarded_for;
13        proxy_set_header  X-Forwarded-Proto $scheme;
14    }
15 }
```

Listing 5.4. Nginx reverse-proxy configuration

5.5.2 IP Access Logging

Nginx logs every request to `/var/log/nginx/access.log`, capturing the client IP address, HTTP method, requested URI, response code, and timestamp. This provides a lightweight but effective access-traceability mechanism without requiring additional tooling. During validation, the Windows host (192.168.56.1) was confirmed to appear in the log with each authenticated session (Figure 5.5).

```

c@CRI-HR-Server:~$ sudo tail -f /var/log/nginx/access.log
[sudo] password for c:
192.168.56.1 - - [29/Apr/2026:09:14:29 +0000] "GET /web/image?model=hr.employee&id=1&field=image_1024&unique=1777454071604 HTTP/1.1" 200 316 "https://192.168.56.101/web/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/147.0.0.0 Safari/537.36 Edg/147.0.0.0"
192.168.56.1 - - [29/Apr/2026:09:14:29 +0000] "GET /web/image?model=hr.employee&id=2&field=image_1024&unique=1777454071598 HTTP/1.1" 200 316 "https://192.168.56.101/web/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/147.0.0.0 Safari/537.36 Edg/147.0.0.0"
192.168.56.1 - - [29/Apr/2026:09:26:45 +0000] "GET /web/login HTTP/1.1" 200 1789 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/147.0.0.0 Safari/537.36"
192.168.56.1 - - [29/Apr/2026:09:26:46 +0000] "GET /web/binary/company_logo HTTP/1.1" 200 8698 "https://192.168.56.101/web/login" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/147.0.0.0 Safari/537.36"
192.168.56.1 - - [29/Apr/2026:09:26:46 +0000] "GET /web/assets/6f0b0e0/web.assets.frontend.min.css HTTP/1.1" 200 497110 "https://192.168.56.101/web/login" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/147.0.0.0 Safari/537.36"
192.168.56.1 - - [29/Apr/2026:09:26:46 +0000] "GET /web/assets/5ec42d9/web.assets.frontend.minimal.min.js HTTP/1.1" 200 11809 "https://192.168.56.101/web/login" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/147.0.0.0 Safari/537.36"
192.168.56.1 - - [29/Apr/2026:09:26:48 +0000] "GET /web/static/src/libs/fontawesome/fonts/fontawesome-webfont.woff2?v=4.7.0 HTTP/1.1" 200 77160 "https://192.168.56.101/web/login" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/147.0.0.0 Safari/537.36"
192.168.56.1 - - [29/Apr/2026:09:26:48 +0000] "GET /web/static/img/favicon.ico HTTP/1.1" 200 1150 "https://192.168.56.101/web/login" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/147.0.0.0 Safari/537.36"
192.168.56.1 - - [29/Apr/2026:09:26:48 +0000] "GET /web/assets/8acaa58/web.assets.frontend_lazy.min.js HTTP/1.1" 200 1557485 "https://192.168.56.101/web/login" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/147.0.0.0 Safari/537.36"
192.168.56.1 - - [29/Apr/2026:09:26:49 +0000] "GET /web/webclient/translations/1777454811269 HTTP/1.1" 200 1318 "https://192.168.56.101/web/login" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/147.0.0.0 Safari/537.36"

```

Figure 5.5. Nginx access log — client IP recorded per authenticated request

5.5.3 Role-Based Access Control

Odoo's native group framework enforces access segregation across three roles:

- **Administrator:** full system access including configuration menus and user management.
- **HR Officer:** can create and approve leave requests, access all employee records, but cannot modify system settings.
- **Employee:** can submit leave requests and view only their own records; all management and configuration menus are hidden.

Each role was validated by attempting restricted operations with the corresponding account and confirming that access was correctly denied. This layered authorisation model limits the blast radius of a compromised low-privilege account and prevents horizontal privilege escalation.

5.5.4 SQL-Injection Audit (SQLmap)

SQLmap was executed against the HTTPS endpoint to probe for SQL-injection vulnerabilities in the Odoo login interface and all reachable web views. After testing all parameters over 432 requests, no injectable entry points were found (Figure 5.6), confirming that Odoo 17's ORM layer correctly parameterises all database queries.

```

[10:45:15] [INFO] testing 'MySQL >= 5.1 error-based - PROCEDURE ANALYSE (EXTRACTVALUE)'
[10:45:16] [INFO] testing 'MySQL >= 5.1 error-based - Parameter replace (EXTRACTVALUE)'
[10:45:16] [INFO] testing 'PostgreSQL error-based - Parameter replace'
[10:45:16] [INFO] testing 'Microsoft SQL Server/Sybase error-based - Stacking (EXEC)'
[10:45:17] [INFO] testing 'Generic inline queries'
[10:45:17] [INFO] testing 'MySQL inline queries'
[10:45:17] [INFO] testing 'PostgreSQL inline queries'
[10:45:17] [INFO] testing 'Microsoft SQL Server/Sybase inline queries'
[10:45:17] [INFO] testing 'Oracle inline queries'
[10:45:17] [INFO] testing 'MySQL >= 5.0.12 stacked queries (comment)'
[10:45:18] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'
[10:45:18] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (comment)'
[10:45:19] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (DECLARE - comment)'
[10:45:20] [INFO] testing 'Oracle stacked queries (DBMS_PIPE.RECEIVE_MESSAGE - comment)'
[10:45:20] [INFO] testing 'MySQL >= 5.0.12 AND time-based blind (query SLEEP)'
[10:45:21] [INFO] testing 'MySQL >= 5.0.12 AND time-based blind (SLEEP)'
[10:45:22] [INFO] testing 'MySQL >= 5.0.12 LIKE time-based blind'
[10:45:22] [INFO] testing 'PostgreSQL > 8.1 AND time-based blind'
[10:45:23] [INFO] testing 'Microsoft SQL Server/Sybase time-based blind (IF)'
[10:45:24] [INFO] testing 'Oracle AND time-based blind'
[10:45:25] [INFO] testing 'MySQL >= 5.0.12 time-based blind - Parameter replace'
it is recommended to perform only basic UNION tests if there is not at least one other (potential) technique found. Do you want to reduce the number of requests? [Y/n]
y
[10:45:25] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'
[10:45:26] [INFO] testing 'MySQL UNION query (NULL) - 1 to 10 columns'
[10:45:27] [WARNING] URI parameter '#1' does not seem to be injectable
[10:45:27] [CRITICAL] All tested parameters do not appear to be injectable. Try to increase values for '--level'/'--risk' options if you wish to perform more tests. If
you suspect that there is some kind of protection mechanism involved (e.g. WAF) maybe you could try to use option '--tamper' (e.g. '--tamper=space2comment') and/or swit
ch '--random-agent'
[10:45:27] [WARNING] HTTP error codes detected during run:
404 (Not Found) - 432 times

[*] ending @ 10:45:27 /2026-04-29/
PS C:\WINDOWS\system32>

```

Figure 5.6. SQLmap execution — 432 tests, 0 injectable parameters detected

5.5.5 Brute-Force Mitigation with Fail2Ban

To protect the ERP authentication interface against automated credential-stuffing and password-spray attacks, Fail2Ban was deployed as an intrusion-prevention layer on the Ubuntu VM host.

The daemon continuously parses `/var/log/nginx/access.log` for repeated POST `/web/login` requests from the same source address. A dedicated jail (`odoo-https`) enforces the following policy: after five failed authentication attempts within a 300-second window, the offending IP address is automatically blocked by a Netfilter DROP rule.

```

1 [odoo-https]
2 enabled    = true
3 port      = 443
4 filter     = odoo-https
5 logpath   = /var/log/nginx/access.log
6 maxretry  = 5
7 findtime  = 300
8 bantime    = 3600

```

Listing 5.5. Fail2Ban jail — `/etc/fail2ban/jail.local`

```

1 [Definition]
2 failregex = ^<HOST> - - .* "POST /web/login HTTP.* 200
3 ignoreregex =

```

Listing 5.6. Fail2Ban filter — `/etc/fail2ban/filter.d/odoo-https.conf`


```

c@CRI-HR-Server:~$ sudo fail2ban-client -t
2026-05-20 08:57:52.521 fail2ban.configreader [2662]: WARNING 'allowipv6' not defined in 'Definition'. Using default one: 'auto'
OK: configuration test is successful
c@CRI-HR-Server:~$ sudo systemctl restart fail2ban
c@CRI-HR-Server:~$ sudo systemctl status fail2ban
● fail2ban.service - Fail2Ban Service
   Loaded: loaded (/usr/lib/systemd/system/fail2ban.service; enabled; preset: enabled)
   Active: active (running) since Wed 2026-05-20 08:59:17 UTC; 10s ago
     Docs: man:fail2ban(1)
   Main PID: 2671 (fail2ban-server)
    Tasks: 7 (limit: 5502)
  Memory: 20.5M (peak: 20.9M)
     CPU: 333ms
    CGroup: /system.slice/fail2ban.service
            └─2671 /usr/bin/python3 /usr/bin/fail2ban-server -xf start

May 20 08:59:17 CRI-HR-Server systemd[1]: Started fail2ban.service - Fail2Ban Service.
May 20 08:59:17 CRI-HR-Server fail2ban-server[2671]: 2026-05-20 08:59:17,532 fail2ban.configreader [2671]: WARNING 'allowipv6' not defined in 'Definition'. U
May 20 08:59:17 CRI-HR-Server fail2ban-server[2671]: Server ready

```

Figure 5.7. Fail2Ban — service active (running), odoo-https jail enabled

5.5.6 File Integrity Monitoring with Auditd

To maintain configuration integrity and enable post-incident forensic analysis, the Linux Audit framework was configured to supervise write and attribute-change events on critical infrastructure files.

```

1 -w /etc/nginx/nginx.conf -p wa -k nginx_config
2 -w /etc/nginx/sites-available/odoo -p wa -k nginx_config
3 -w /home/odoo/docker-compose.yml -p wa -k docker_config
4 -w /home/odoo/Dockerfile -p wa -k docker_config

```

Listing 5.7. Auditd watch rules — /etc/audit/rules.d/cri.rules

Any modification to these files generates a structured audit record in /var/log/audit/audit.log, capturing the timestamp, process identifier, and user identity responsible for the change. This provides a verifiable audit trail for both compliance purposes and incident response.

```

c@CRI-HR-Server:~$ sudo systemctl restart auditd
c@CRI-HR-Server:~$ sudo systemctl status auditd
● auditd.service - Security Auditing Service
   Loaded: loaded (/usr/lib/systemd/system/auditd.service; enabled; preset: enabled)
   Active: active (running) since Wed 2026-05-20 09:16:15 UTC; 2s ago
     Docs: man:auditd(8)
            https://github.com/linux-audit/audit-documentation
   Process: 3207 ExecStart=/sbin/auditd (code=exited, status=0/SUCCESS)
   Process: 3212 ExecStartPost=/sbin/augenrules --load (code=exited, status=0/SUCCESS)
   Main PID: 3209 (auditd)
    Tasks: 2 (limit: 5502)
  Memory: 492.0K (peak: 2.1M)
     CPU: 88ms
    CGroup: /system.slice/auditd.service
            └─3209 /sbin/auditd

May 20 09:16:15 CRI-HR-Server augenrules[3226]: enabled 1
May 20 09:16:15 CRI-HR-Server augenrules[3226]: failure 1
May 20 09:16:15 CRI-HR-Server augenrules[3226]: pid 3209
May 20 09:16:15 CRI-HR-Server augenrules[3226]: rate_limit 0
May 20 09:16:15 CRI-HR-Server augenrules[3226]: backlog_limit 8192
May 20 09:16:15 CRI-HR-Server augenrules[3226]: lost 0
May 20 09:16:15 CRI-HR-Server augenrules[3226]: backlog 4
May 20 09:16:15 CRI-HR-Server augenrules[3226]: backlog_wait_time 60000
May 20 09:16:15 CRI-HR-Server augenrules[3226]: backlog_wait_time_actual 0
May 20 09:16:15 CRI-HR-Server systemd[1]: Started auditd.service - Security Auditing Service.
c@CRI-HR-Server:~$

```

Figure 5.8. Auditd — watch rules applied, service active (running)

5.5.7 Real-Time Infrastructure Monitoring with Netdata

Netdata was deployed on the Ubuntu VM to provide continuous visibility over system behaviour during both normal operation and simulated attack conditions. The agent collects over 4 500 metrics per second, covering CPU utilisation, memory pressure, disk I/O, and network throughput, and exposes them through a live web dashboard accessible at <http://192.168.56.101:19999>.

During the attack simulation described below, Netdata provided real-time confirmation of the network-traffic and CPU spikes generated by the brute-force tool, demonstrating that the monitoring layer responds correctly to adversarial activity.

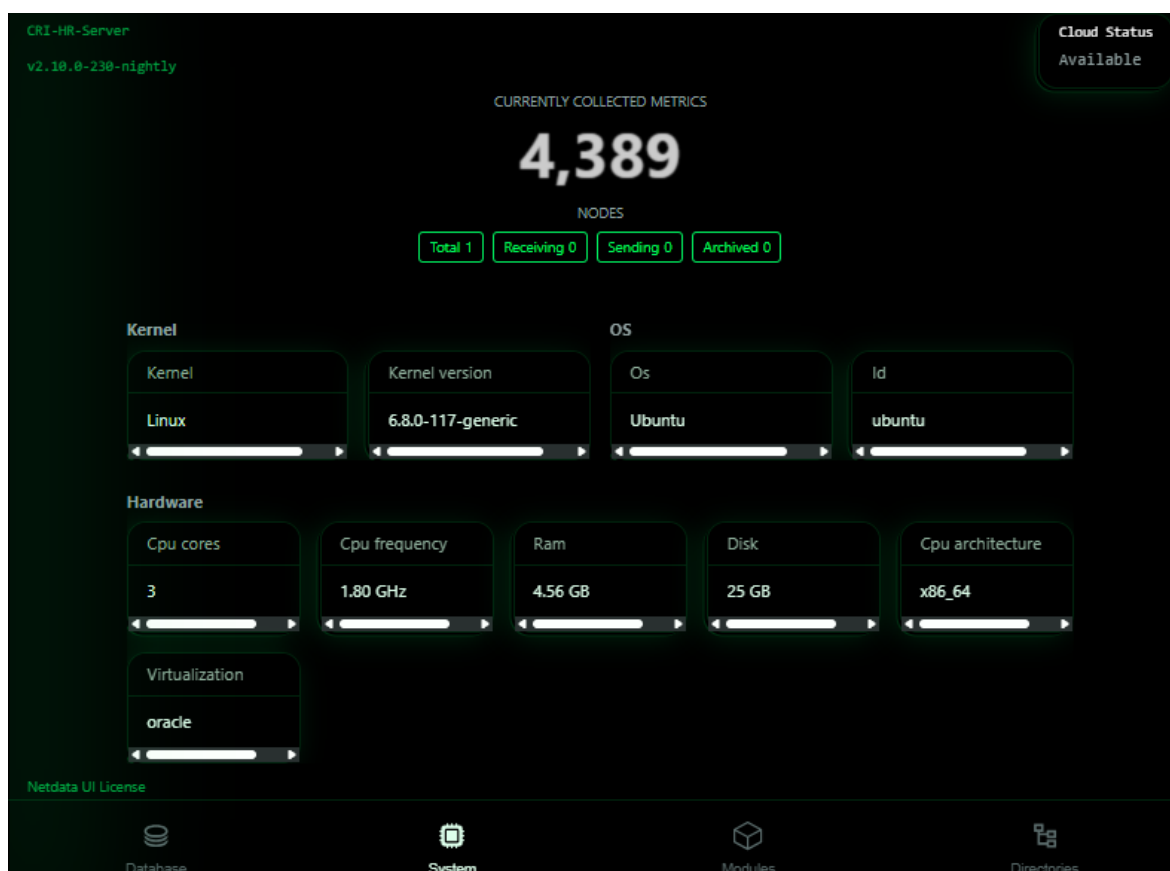


Figure 5.9. Netdata dashboard — live CPU, RAM, and network metrics

5.5.8 Attack Simulation and Incident Response Validation

A controlled end-to-end attack scenario was executed to validate the effectiveness of the deployed security stack.

Attack environment. The brute-force tool `hydra` was run from a Kali Linux VM connected to the same Host-Only network (192.168.56.0/24), simulating an attacker with internal network access. This represents the most relevant threat model for an HR application deployed on a corporate LAN.

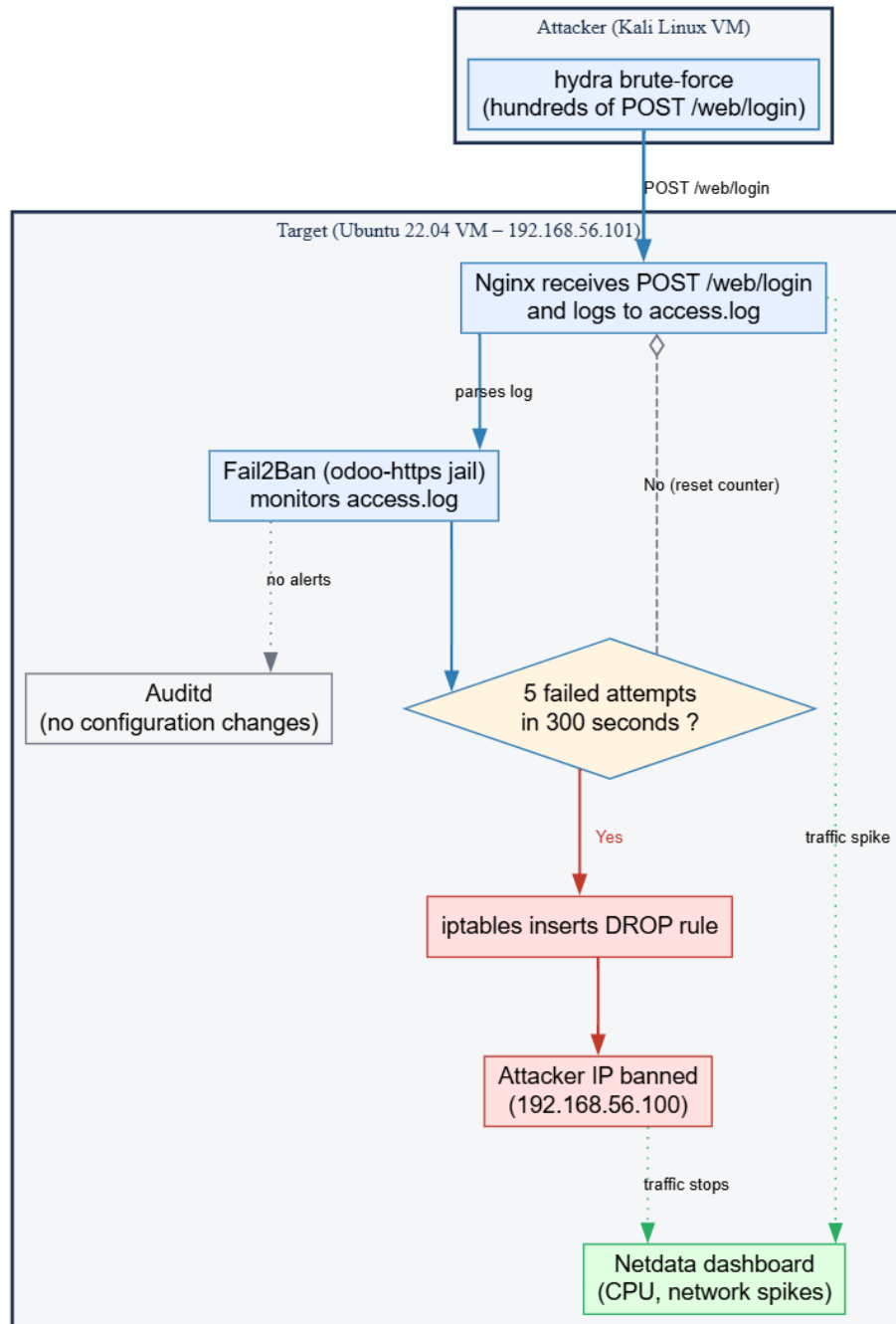


Figure 5.10. Attack flow: brute-force detection and automatic mitigation by Fail2Ban, with parallel monitoring by Netdata and Auditd.

Brute-force simulation. A password-spray attack against the Odoo HTTPS login endpoint was conducted using `hydra` with a 20-entry password list:

```

1 hydra -l admin@example.com \
2   -P /usr/share/wordlists/rockyou-small.txt \
3   -s 443 -S \
4   192.168.56.101 \
5   https-post-form "/web/login:login=~USER^&password=~PASS^:Invalid
  "

```

Listing 5.8. Brute-force simulation with Hydra

After five consecutive failed attempts, Fail2Ban inserted a DROP rule and all subsequent connection attempts from the attacker IP were silently discarded. The ban was verified immediately:

```

1 $ fail2ban-client status odoo-https
2 Status for the jail: odoo-https
3 |- Filter
4 |   |- Currently failed: 0
5 |   '- Total failed:      5
6 '- Actions
7     |- Currently banned: 1
8     '- Banned IP list:   192.168.56.100

```

Listing 5.9. Fail2Ban ban verification

```

1 $ sudo iptables -L f2b-odoo-https -n
2 Chain f2b-odoo-https (1 references)
3 target    prot opt source                destination
4 REJECT    all  --  192.168.56.100          0.0.0.0/0
5 RETURN    all  --  0.0.0.0/0              0.0.0.0/0

```

Listing 5.10. iptables DROP rule confirmation

Monitoring confirmation. The Netdata dashboard showed a visible traffic spike during the brute-force phase, then a sharp drop once the ban was enforced — visually confirming that the monitoring layer detects and reflects the mitigation in real time.

Integrity verification. No events were generated in `/var/log/audit/audit.log` during the attack, confirming that the attacker did not reach — and therefore could not modify — any infrastructure configuration file.

Table 5.1 summarises the full security architecture.

Table 5.1. Security controls — implementation and validation summary

Control	Mechanism	Validated
Transport encryption	Nginx + OpenSSL TLS (RSA-4096)	Yes
Access traceability	Nginx IP logging	Yes
Authorisation	Odoo RBAC (3 roles)	Yes
Injection resistance	SQLmap — 0 findings	Yes
Brute-force mitigation	Fail2Ban (odoo-https jail)	Yes
File integrity audit	Auditd (write/attr rules)	Yes
Infrastructure monitor	Netdata (4,500+ metrics/s)	Yes

Results and Analysis

6.1 Functional Results

All functional requirements defined in Table 2.1 were successfully implemented and validated. The HTTPS interface was reachable exclusively over port 443; direct HTTP connections on port 8069 were blocked at the firewall level. Employee records, leave requests, and leave approvals operated correctly across the three RBAC roles, with access boundaries confirmed by systematic negative testing (attempting restricted operations with low-privilege accounts).

6.2 Performance Metrics

A load test was conducted with Apache Bench (100 requests, concurrency 10) against the HTTPS endpoint. The mean response time was **0.325 s** with zero failures, demonstrating that the Nginx–Odoo–PostgreSQL stack sustains light concurrent load within acceptable latency bounds for an internal HR application serving a team of approximately twenty people.

The TLS handshake overhead introduced by the self-signed certificate did not measurably affect response times at this concurrency level.

6.3 Security Validation Results

- **SQLmap:** 432 tests executed, 0 injectable parameters detected.
- **Fail2Ban:** ban enforced correctly after 5 failed attempts; DROP rule confirmed in iptables.
- **Auditd:** 0 spurious events during normal operation, confirming a low false-positive rate for the integrity monitoring rules.
- **Netdata:** attack-phase traffic spike clearly visible in the network-throughput graph, confirming real-time detection capability.

6.4 Comparison with Initial Objectives

Table 6.1. Initial objectives vs. achieved outcomes

Objective	Status	Notes
HR module (employee CRUD, leave workflow)	Full	
HTTPS + Nginx reverse proxy	Full	Self-signed cert
RBAC (3 roles)	Full	Verified
IP access logging	Full	Nginx log
SQL-injection audit	Full	0 findings
Brute-force mitigation	Full	Fail2Ban
File integrity monitoring	Full	Auditd
Real-time monitoring	Full	Netdata
Deployment on production server	~ Not required	Virtual simulation sufficient for validation

Discussion and Professional Interpretation

7.1 Achievement vs. Requirements

The project delivered a fully functional and security-hardened HR prototype within the six-week constraint. All functional requirements were implemented; all security controls were validated through automated tooling or controlled simulation. The final architecture demonstrates that a defence-in-depth security posture is achievable on minimal hardware, using exclusively open-source, well-maintained Linux primitives, without requiring proprietary security platforms or cloud infrastructure.

7.2 Identified Limitations and Engineering Trade-offs

- **Self-signed certificate.** The current TLS certificate triggers a browser security warning. A production rollout would require a CA-signed certificate (e.g. Let's Encrypt) and a publicly resolvable domain name.
- **VM-only deployment for validation.** The prototype uses a Host-Only network, which is appropriate for validation but would require adaptation (firewall, DMZ, VPN) for a production environment.
- **Resource constraints driving tooling decisions.** The available 4.5 GB RAM made it impossible to deploy Wazuh, the originally planned SIEM solution. This constraint drove the adoption of lightweight native Linux security tooling — a deliberate engineering trade-off that prioritises operational stability over feature completeness, and that resulted in a more transparent and maintainable security stack.
- **Limited concurrent user testing.** Only simulated user accounts were used; real-world usage patterns with concurrent sessions were not benchmarked beyond the Apache Bench load test.
- **No automated backup.** PostgreSQL data volumes are not backed up. A production deployment would require scheduled `pg_dump` exports and verified off-site storage.

7.3 Contributions

For the CRI. The prototype provides a concrete proof of concept: a secure, ERP-based HR solution is technically achievable, with a total infrastructure footprint of one Ubuntu VM and

three Docker containers. The configuration files and security controls documented in this report constitute a reusable baseline for a future production rollout.

For the RIS field. The project illustrates how standard Linux security primitives — Nginx, Fail2Ban, Auditd, Netdata — can be composed into a coherent layered defence around an open-source ERP without relying on heavyweight or proprietary platforms.

7.4 The Role of AI in Modern Cybersecurity

Artificial intelligence is increasingly integrated into security operations: machine learning models detect behavioural anomalies in authentication logs, identify lateral movement patterns across network telemetry, and automate threat prioritisation at a scale that manual rule-based systems cannot match.

Although this project did not implement AI-based controls, future extensions are clearly motivated. A lightweight anomaly-detection model applied to Fail2Ban’s log stream could reduce false positives and detect low-and-slow brute-force patterns that fall below the fixed threshold. Similarly, an AI agent monitoring Netdata’s metric stream could flag infrastructure deviations — memory leaks, abnormal disk writes — that deterministic thresholds would miss. Both extensions would move the architecture towards a Zero Trust posture, in which every access decision is informed by continuous, data-driven risk assessment rather than static rules.

7.5 Future Work

The following improvements represent a prioritised roadmap for evolving CRI-HR-Secure from a validated prototype into a production-grade system:

1. **CA-signed TLS certificate (Let’s Encrypt).** Replace the self-signed certificate with a free, automatically renewable certificate from Let’s Encrypt, eliminating the browser security warning and making the system ready for end users without manual exception handling.
2. **Deployment on a hardened server.** Migrate from the VirtualBox VM to a dedicated server within a corporate network, with a perimeter firewall, a DMZ segment, and a VPN for administrative access.
3. **Web Application Firewall (ModSecurity or CrowdSec [11]).** Add a WAF layer in front of Nginx to filter HTTP-level attacks (XSS, path traversal, bot traffic) that SQLmap and Fail2Ban do not address. CrowdSec, being community-driven and lightweight, is particularly well suited to resource-constrained environments.
4. **LDAP / Active Directory integration.** Replace local Odoo accounts with centralised LDAP authentication, enabling single sign-on and simplifying user lifecycle management.
5. **Two-factor authentication (2FA) for privileged accounts.** Enforce TOTP-based 2FA for the Administrator and HR Officer roles, reducing the residual risk from compromised

passwords.

6. **Automated PostgreSQL backups.** Schedule nightly `pg_dump` exports to an off-site storage location, with automated restore testing to guarantee data recoverability.

Conclusion

This six-week internship resulted in the design and deployment of CRI-HR-Secure, a secure HR module prototype for the Regional Investment Centre of Guelmim. Despite the typical constraints of an academic internship (no production server access), a fully functional and security-hardened system was delivered on a virtual machine simulating an internal network.

The prototype implements all required HR functions and a seven-layer security architecture validated through penetration testing, controlled attack simulation, and systematic functional testing. The project directly demonstrates the competencies targeted by the RIS programme: network architecture, system security, and Linux server administration applied to a real organisational problem.

Future work should address the identified limitations: replacement of the self-signed certificate with a CA-signed one, deployment on a hardened server, integration of LDAP authentication for single sign-on, and addition of two-factor authentication for administrator accounts. In the longer term, the prototype provides a natural starting point for a full production ERP deployment, with a well-documented security baseline already in place.

Bibliography

- [1] Odoo S.A. (2025). *Odoo 17 Documentation — Human Resources Module*. <https://www.odoo.com/documentation/17.0/applications/hr.html>
- [2] Docker, Inc. (2026). *Docker Documentation — Get Started with Docker*. <https://docs.docker.com/get-started/>
- [3] Nginx, Inc. (2025). *NGINX Reverse Proxy and SSL/TLS Termination*. <https://nginx.org/en/docs/>
- [4] OpenSSL Project. (2025). *OpenSSL Manual — Certificate and Key Generation*. <https://www.openssl.org/docs/>
- [5] Damele, B. & Guimaraes, M. (2025). *SQLmap — Automatic SQL Injection and Database Takeover Tool*. <https://sqlmap.org/>
- [6] Fail2Ban Project. (2026). *Fail2Ban Documentation*. <https://www.fail2ban.org/>
- [7] Linux Audit Project. (2026). *Linux Audit System — auditd(8) Manual Page*. <https://linux.die.net/man/8/auditd>
- [8] Netdata, Inc. (2026). *Netdata Documentation — Infrastructure Monitoring*. <https://learn.netdata.cloud/>
- [9] OWASP Foundation. (2021). *OWASP Top Ten — The Ten Most Critical Web Application Security Risks*. <https://owasp.org/www-project-top-ten/>
- [10] Nabhen, R. (2024). *Linux Audit System — Understanding auditd and Audit Rules*. Linux Audit Project. <https://linux-audit.com/linux-audit-framework-overview/>
- [11] CrowdSec. (2026). *CrowdSec Documentation — Collaborative Intrusion Prevention*. <https://docs.crowdsec.net/>
- [12] National Institute of Standards and Technology (NIST). (2023). *SP 800-53 Rev. 5 — Security and Privacy Controls for Information Systems*. <https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final>

Configuration Files

Nginx — /etc/nginx/sites-available/odoo

```
1 server {
2     listen 443 ssl;
3     server_name 192.168.56.101;
4     ssl_certificate      /etc/ssl/certs/cert.pem;
5     ssl_certificate_key  /etc/ssl/private/key.pem;
6     location / {
7         proxy_pass        http://localhost:8069;
8         proxy_set_header  Host            $host;
9         proxy_set_header  X-Real-IP       $remote_addr;
10        proxy_set_header  X-Forwarded-For
11            $proxy_add_x_forwarded_for;
12        proxy_set_header  X-Forwarded-Proto $scheme;
13    }
```

Fail2Ban — /etc/fail2ban/jail.local

```
1 [odoo-https]
2 enabled = true
3 port    = 443
4 filter  = odoo-https
5 logpath = /var/log/nginx/access.log
6 maxretry = 5
7 findtime = 300
8 bantime  = 3600
```

Fail2Ban — /etc/fail2ban/filter.d/odoo-https.conf

```
1 [Definition]
2 failregex = ^<HOST> - - .* "POST /web/login HTTP.* 200
3 ignoreregex =
```

Auditd — /etc/audit/rules.d/cri.rules

```
1 -w /etc/nginx/nginx.conf          -p wa -k nginx_config
2 -w /etc/nginx/sites-available/odoo -p wa -k nginx_config
3 -w /home/odoo/docker-compose.yml  -p wa -k docker_config
4 -w /home/odoo/Dockerfile           -p wa -k docker_config
```

SQLmap Execution Log (Extract)

SQLmap was run against `https://192.168.56.101/web` with default settings. Relevant extract:

```
1 [INFO] testing connection to the target URL
2 [INFO] heuristic (basic) test GET parameter ... is dynamic
3 [WARNING] GET parameter ... does not seem injectable
4 [CRITICAL] all tested parameters do not appear to be injectable
5 [INFO] no injectable parameters detected
6 [*] ending @ 10:45:27 /2026-04-29/
```

Result: 432 tests, 0 SQL-injection vulnerabilities detected.